codigo.c

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Worked for 7s >

Este arquivo é malware (especificamente, um backdoor/rootkit de rede para Linux, ativado por "magic packet").

Análise passo a passo

1. **Requisitos e persistência inicial**
   - Exige root (`getuid() != 0` → sai).
   - Cria um arquivo PID em `/var/run/haldrund.pid` para evitar múltiplas instâncias.
   - Se executado sem argumentos, tenta se copiar para `/dev/shm/` (tmpfs), renomear, tornar executável e rodar com `--init` , depois remove o original. Isso é técnica clássica de stealth/persistência em memória.
2. **Camuflagem de processo**
   - Troca o nome do processo (`set_proc_name` + `prctl(PR_SET_NAME)`) para nomes legítimos de sistema escolhidos aleatoriamente:
     - `/sbin/udevd -d`
     - `/sbin/mingetty /dev/tty7`
     - `hald-addon-acpi...`
     - `dbus-daemon --system`
     - `avahi-daemon: chroot helper`
     - etc.
   - Também zera o ambiente e o argv original. Isso dificulta a detecção via `ps` , `top` , etc.
3. **Timestamps falsos**
   - `setup_time()` força timestamps antigos (2008) no binário para parecer legítimo.
4. **Sniffer de pacotes com BPF**
   - Abre socket raw (`PF_PACKET` , `ETH_P_IP`).
   - Aplica um filtro BPF bem específico que procura por:
     - IP
     - Protocolos TCP / UDP / ICMP
     - Portas mágicas (0x7255 = 29269 e 0x5293 = 21139 em alguns caminhos)
   - Ao receber o pacote, interpreta a estrutura `magic_packet` (flag + IP + porta + senha de até 14 bytes).
5. **Ativação por "magic packet"**

Copied link to clipboard. Shared links can be viewed by anyone with the link.

- Senhas hardcoded (em hex):
  - `justforfun`
  - `socket`
- Comportamento conforme a senha:
  - Uma senha → `try_link()` (conexão de volta / reverse) + shell criptografado.
  - Outra → `getshell()` (cria listener local + regras iptables NAT/REDIRECT + shell).
  - Outra → apenas envia um pacote de "monitoramento" (`mon()`).
- O processo filho faz double-fork, `setsid()` , muda de diretório para `/` e troca novamente o nome do processo para algo como `/usr/libexec/postfix/master` .

6. **Shell interativo criptografado**
   - Função `shell()` :
     - Abre PTY (pseudo-terminal).
     - Usa RC4 (com a senha do magic packet como chave) para criptografar/descriptografar todo o tráfego (`cwrite` / `cread`).
     - Spawna `/bin/sh` com ambiente limpo e histórico redirecionado para `/dev/null` .
     - Suporta redimensionamento de terminal (via caractere de controle 0x0b).
   - Em um dos caminhos (`getshell`) manipula iptables (`nat PREROUTING` + `INPUT ACCEPT`) para redirecionar portas e facilitar o acesso.
7. **Outros indicadores de malware**
   - Strings ofuscadas em arrays de bytes (comandos `rm` , `cp` , `chmod` , `iptables` , nomes de processos, etc.).
   - Tratamento de sinais para limpeza do PID file.
   - Uso de `vhangup()` , manipulação de winsize, etc., típico de backdoors sofisticados.
   - Não há nenhuma funcionalidade legítima (não é um daemon de sistema, não é um utilitário de rede comum, não é um sniffers de diagnóstico).

Conclusão

O código implementa um **backdoor de ativação por pacote mágico** (packet-triggered rootkit/backdoor), com:

- Esconderijo de processo
- Criptografia RC4 no shell
- Manipulação de iptables
- Persistência em `/dev/shm`
- Camuflagem completa

Não existe interpretação benigna plausível pa
de malware.

Copied link to clipboard. Shared links can be viewed by anyone with the link.

Qual é a categoria principal deste malware?

Worked for 5s >

Backdoor (especificamente um *packet-triggered backdoor* / backdoor ativado por magic packet).

Por que essa é a categoria principal?

- A funcionalidade central do código é **abrir um shell remoto criptografado** (com RC4) sob comando de um atacante.
- Ele fica escutando passivamente a rede (socket raw + filtro BPF) à espera de um pacote especial ("magic packet") contendo senha + IP + porta.
- Ao receber o pacote correto, executa uma das ações de acesso remoto:
  - Conexão reversa (`try_link` + shell)
  - Listener local + redirecionamento via iptables (`getshell`)
  - Pacote de monitoramento

Todas as outras técnicas presentes (camuflagem de nome de processo, PID file, cópia para `/dev/shm` , timestamps falsos, ofuscação de strings, etc.) são apenas mecanismos de **stealth e persistência** que servem para manter o backdoor vivo e difícil de detectar. Elas não mudam a natureza principal do malware.

Em taxonomias comuns de malware, portanto, a classificação principal é:

Backdoor → subtipo: *Network/Packet-activated Backdoor* (às vezes também chamado de *Covert Channel Backdoor* ou *Magic Packet Backdoor*).

↘ Qual é a categoria do malware?

↘ Explique a ofuscação de strings

↘ Como detectar este malware

Copied link to clipboard. Shared links can be viewed by anyone with the link.